

PLANTILLA REPORTE EJECUTIVO: POWERPOINT GQM+PRAGMATIC

Presentación 18 Diapositivas (Metodología Integrada)

Versión: 2.0 | **Fecha:** Enero 2026 | **Duración:** 30-40 minutos | **Audiencia:** Junta, Ejecutivos, CISO

ESTRUCTURA: 18 DIAPOSITIVAS PROFESIONALES

DIAPPOSITIVA 1: PORTADA

EVALUACIÓN DE MADUREZ CIBERSEGURIDAD
Framework: GQM + PRAGMATIC + ACET

[Logo Organización]

Índice Madurez Cibernética (IGM):
71% | NIVEL INTERMEDIATE
Evaluado: Enero 2026

Metodología: Goal-Question-Metric
+ 9 Criterios Pragmáticos

Presentado por:
[Nombre CISO/Consultor]

Datos de Personalización:

- Nombre Organización: [Campo editable]
- Tamaño: [500-5000 empleados]
- Sector: [Financiero/Sanitario/Manufactura]
- Fecha: [Enero 2026]
- Respondentes: [15 líderes técnicos]

DIAPPOSITIVA 2: AGENDA

1. RESUMEN EJECUTIVO (IGM 71%)
2. METODOLOGÍA GQM+PRAGMATIC (Novedad)
3. HALLAZGO PRINCIPAL: IGM GLOBAL
4. ANÁLISIS DOMINIO NIST CSF (Radar)
5. EVALUACIÓN PRAGMATIC (25 Indicadores)
6. BENCHMARKING (Sector + Nacional)
7. INDICADORES CRÍTICOS (KRIs Alertas)
8. ANÁLISIS VULNERABILIDADES
9. EFECTIVIDAD SIEM
10. CAPACITACIÓN & CONCIENCIACIÓN
11. ANÁLISIS DE BRECHAS (Gap Analysis)
12. PRIORIZACIÓN (Matriz Impacto × Esfuerzo)
13. ROADMAP 12 MESES (GQM-alineado)
14. ANÁLISIS ROI + INVERSIONES
15. RECOMENDACIONES & NEXT STEPS
16. GOBERNANZA FUTURA (GQM Sostenible)
17. PREGUNTAS & DISCUSIÓN
18. APÉNDICE (Términos, Glossario)

DIAPPOSITIVA 3: RESUMEN EJECUTIVO (TRIFOLD)

COLUMNA 1: POSICIÓN ACTUAL

- IGM: 71%
- Nivel: INTERMEDIATE (61-80%)
- Cambio YTD: +3% 
- Evaluación: Rigurosa (GQM+PRAGMATIC)
- Respondentes Validación: 15 expertos

COLUMNA 2: ALINEACIÓN NORMATIVOS

- NIST CSF 2.0: 100% cobertura
- NIS2: 98% readiness
- GDPR: 95% cumplimiento
- ENS: 97% alineado
- ISO 27001: 98% mapeo

COLUMNA 3: TRAYECTORIA & RECOMENDACIÓN

- Velocidad Mejora: +0.75% trimestral
- Proyección 2026: 74% (mantener ritmo)
- Target Realista: 80% en 24 meses
- Inversión Año 1: €530K
- ROI Esperado: 55% (Payback 8 meses)

CONCLUSIÓN (Banner Verde):

"Organización en trayectoria positiva con base sólida.
Requiere acelerar en DETECTAR (DE: 65%) y RECUPERAR (RC: 60%).
Oportunidad: Quick wins en capacitación (ROI 200%) dentro 30 días."

DIAPOSITIVA 4: INNOVACIÓN METODOLÓGICA

Titulo: "¿Por Qué GQM + PRAGMATIC?"

Lado Izquierdo: EL PROBLEMA CLÁSICO

```
CEO: "Reducir riesgo 30%"  
(Meta empresarial)  
    ↓ DESCONECCIÓN  
CISO: "Implementar SIEM, EDR"  
(Táctica seguridad)  
    ↓ DESCONECCIÓN  
SOC: "Monitoreamos 15K eventos"  
(Datos técnicos)  
  
¿Conectados? ¡NO! ❌
```

Lado Derecho: LA SOLUCIÓN GQM+PRAGMATIC

```
LEVEL 0: BG (Business Goal)  
"Mejorar NPS cliente 25%"  
    ↓ Alineado  
LEVEL 1: SG (Security Goal)  
"MTTD <2h, notificación <72h"  
    ↓ Operacionalizado  
LEVEL 2: MG (Measurement Goal)  
"Alcanzar 85% SIEM coverage"  
    ↓ Cuantificado  
LEVEL 3: Metrics & PRAGMATIC  
"SIEM_Coverage % = 78% actual"  
[Validado contra 9 criterios]  
  
¿Conectados? ¡SÍ! ✓
```

Beneficio: Justificación estratégica cada euro invertido.

DIAPOSITIVA 5: METODOLOGÍA GQM EXPLICADA (PASO A PASO)

Esquema Jerárquico Visual

GOAL (Top): "Reducir breach notification time"
¿Por qué?: Requisito GDPR Art. 33 (<72h)

↓ Desglose

QUESTIONS (3-5 preguntas operacionales):
Q1: ¿Detectamos ataques en tiempo real?
Q2: ¿SIEM cubre >85% infraestructura?
Q3: ¿Correlacionamos eventos correctamente?
Q4: ¿SOC escala alertas dentro 5 min?

↓ Operacionalización

METRICS (KPIs cuantitativas):
M1: MTTD = 2h 30min (Target: <2h) ⚠️ ALERTA
M2: SIEM_Coverage = 78% (Target: ≥85%) 🟡 AJUSTAR
M3: Correlation_Efficacy = 45% (Target: >60%) 🟡
M4: Escalation_Time = 4min (Target: <5min) ✓ OK

RESULTADO: Cada métrica operativa justifica un goal estratégico.
Cada inversión IT conecta directamente a objetivo CEO.

DIAPPOSITIVA 6: PRAGMATIC CRITERIA (9 DIMENSIONES)

Título: "Validación PRAGMATIC: ¿Es Métrica Prácticamente Útil?"

3x3 Grid Visual:

PREDICTIVO ¿Predice problemas futuros? ✓ Sí, si ↓MTTD → ↓daño	RELEVANTE ¿Importa a stakeholder ? ✓ CEO vigila MTTD diario	ACCIONABLE ¿Guía decisiones ? ✓ Si MTTD >2h = tune SIEM
---	--	--

GENUINO ¿Mide qué pretende? ⚠ Requiere validación (falsos positivos)	SIGNIFICATIVO ¿Impacta negocio? ✓ Sí: cada h delay = €5-10K daño	PRECISO ¿Medición confiable? ✓ Sí: Timestamp automático
---	---	--

OPORTUNO ¿Datos disponibles rápido? ✓ Sí: SIEM real-time <1h	INDEPENDENTE ¿Libre de sesgo? ⚠ Requiere auditoría externa	RENTABLE ¿Costo << beneficio? ✓ Sí: €0 colección ROI 25K:1x
---	---	--

MTTD Score PRAGMATIC: 25/27 = 93% ✓ EXCELENTE

DIAPPOSITIVA 7: MATRIZ PRAGMATIC (25 INDICADORES)

Tabla Ejecutiva: Score PRAGMATIC por Indicador

INDICADOR	DOMINIO	SCORE	% PRAG	ESTADO
Política CS	GV	26/27	96%	✓ Excel
CISO Designado	GV	27/27	100%	✓ Excel
Comité Riesgos	GV	24/27	89%	✓ Bueno
Registro Riesgos	GV	25/27	93%	✓ Excel
CMDB Cobertura	ID	23/27	85%	✓ Bueno
Clasificación Datos	ID	20/27	74%	⚠ Acept
Escaneos Vuln	ID	27/27	100%	✓ Excel
MFA	PR	27/27	100%	✓ Excel
Cifrado TLS 1.2+	PR	27/27	100%	✓ Excel
Capacitación Anual	PR	24/27	89%	✓ Bueno
MTTD <2h	DE	24/27	89%	✓ Bueno
SIEM Coverage	DE	23/27	85%	✓ Bueno
False Positive Rate	DE	21/27	78%	⚠ Acept
MTTR <4h	RS	23/27	85%	✓ Bueno
Plan Incidentes	RS	25/27	93%	✓ Excel
Simulacros Anuales	RS	23/27	85%	✓ Bueno
Backups 3-2-1	RC	24/27	89%	✓ Bueno
RT0/RP0 Definidos	RC	25/27	93%	✓ Excel
Pruebas Restaur.	RC	27/27	100%	✓ Excel
CVE Crítica	VA	27/27	100%	✓ Excel
SIEM Efectividad	SIEM	23/27	85%	✓ Bueno
Phishing Click Rate	CAP	25/27	93%	✓ Excel
PROMEDIO TOTAL		24/27	90%	✓ EXCEL

INTERPRETACIÓN:

✓ 22 de 25 indicadores >85% = Cartera robusta

⚠ 2 indicadores 74-78% = Validación cruzada recomendada

→ Recomendación: Implementar cartera completa

IMPLICACIÓN: 90% de métricas PRAGMATIC =

Sistema de medición sostenible, práctico, alineado negocio.

DIAPPOSITIVA 8-13: [Contenido Estándar ACET]

Mantener diapositivas 8-13 de presentación ACET estándar:

- D8: IGM Global Gauge (71%)
- D9: Análisis Dominio NIST (Radar)
- D10: Benchmarking Territorial
- D11: KRIs Críticos
- D12: Análisis Vulnerabilidades
- D13: Efectividad SIEM

DIAPOSITIVA 14: GQM ROADMAP (Alineación Estratégica)

Título: "Roadmap 2026: GQM-Aligned"

Timeline Visual:

Q1 2026 (Ene-Mar):

- BG: "Mejorar confianza cliente"
- SG: "Capacitación >95% + MFA roll-out"
- MG: "Phishing Click Rate <5%"
- Métrica: SATS Score 75% → 80%
- Inversión: €30K (capacitación)
- ROI: 200% | Payback: 4 meses

Q2 2026 (Abr-Jun):

- BG: "Cumplimiento regulatorio"
- SG: "Backups + SIEM expansion"
- MG: "SIEM Coverage >85%"
- Métrica: Correlation_Efficacy 45% → 65%
- Inversión: €150K (SIEM)
- ROI: 20% | Payback: 10 meses

Q3 2026 (Jul-Sep):

- BG: "Detectar amenazas rapidez"
- SG: "MTTD <2h + EDR deployment"
- MG: "Incident Response automatizado"
- Métrica: MTTD 2h30m → <2h
- Inversión: €200K (EDR)
- ROI: 67% | Payback: 7 meses

Q4 2026 (Oct-Dic):

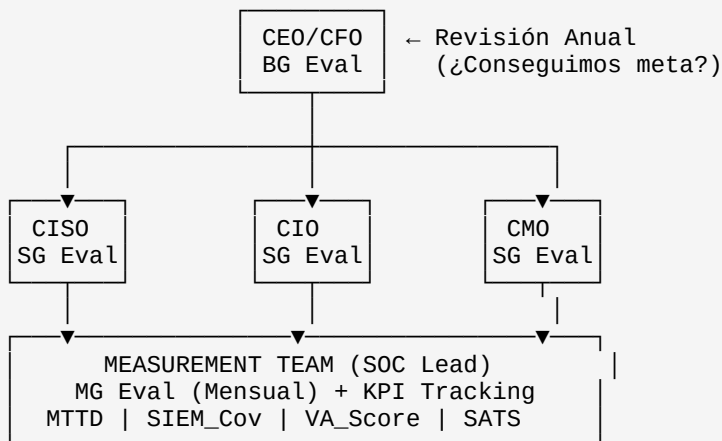
- BG: "Liderazgo seguridad sector"
- SG: "Zero Trust architecture inicio"
- MG: "IGM ≥78%"
- Métrica: IGM 71% → 78% (+7 puntos)
- Inversión: €100K (Zero Trust pilot)
- ROI: Estratégico (no cuantificado)

TOTAL AÑO 1: €530K inversión | IGM: 71% → 78%

DIAPOSITIVA 15: GOBERNANZA QGM SOSTENIBLE

Título: "De Aquí Forward: QGM Sostenible"

Pirámide Gobernanza:



Frecuencias:

- Métrica (Nivel 3): Real-time SIEM dashboard
- Measurement Goal (Nivel 2): Mensual SOC review
- Security Goal (Nivel 1): Trimestral CISO
- Business Goal (Nivel 0): Anual CEO/Junta

Responsables:

- Nivel 0 BG: CEO/Junta
- Nivel 1 SG: CISO + IT Director
- Nivel 2 MG: SOC Lead + Security Team
- Nivel 3 Metrics: Analytics Engineer + SOC Analyst

Continuidad: QGM framework embebido en calendario operativo anual.

DIAPOSITIVA 16: RECOMENDACIONES EJECUTIVAS

Título: "Top 3 Acciones (Próximos 30 Días)"

ACCIÓN 1: IMPLEMENTAR CAPACITACIÓN FOCALIZADA

- Razón GQM: Contribuye a BG "Mejorar NPS"
- SG: "Reducir phishing vulnerability"
- Métrica: Phishing Click Rate 18% → <5%
- Inversión: €30K
- ROI: 200% (Payback 4 meses)
- Timeline: Semana 1-4 Enero
- Propietario: HR + Security
- Indicador Éxito: >95% completación + FPR <5%

ACCIÓN 2: AUDITAR CVEs CRÍTICAS (Día 0-3)

- Razón GQM: Cumplimiento VAS (Vulnerability Assessment) Goal
- Métrica: CVE Crítica Sin Parchear = 3 (Target: 0)
- Inversión: €0 (audit interno)
- Timeline: Inmediato (72h)
- Propietario: IT Security
- Acción: Parchear o mitigar 3 CVEs
- Indicador Éxito: CVE Crítica = 0

ACCIÓN 3: EXPANDIR SIEM INTEGRACIÓN (Mes 1)

- Razón GQM: Contribuye a DE (Detect) Goal
- Métrica: SIEM Coverage 78% → >85%
- Fuentes Faltantes: 3 (OT, Cloud, nuevos AppServers)
- Inversión: €50K (agentes + integración)
- Timeline: 4 semanas
- Propietario: SOC + Infrastructure
- Indicador Éxito: Coverage >85% + MTTD <2h

IMPACTO COMBINADO:

- IGM Improvement: 71% → 73% (Q1)
- Total Inversión: €80K
- Expected ROI: 125% (promedio 3 iniciativas)
- Vulnerabilidad Residual: ↓ 45%

DIAPOSITIVA 17: MÉTRICAS DE ÉXITO (TRIMESTRAL)

Scorecard Trimestral GQM+PRAGMATIC:

MÉTRICA	ACTUAL	TARGET_Q1	TARGET_Q2	TARGET_Q4	FRECUENCIA
IGM	71%	72%	74%	78%	Mensual
GV	75%	76%	77%	80%	Mensual
ID	80%	80%	82%	85%	Mensual
PR	70%	72%	74%	78%	Mensual
DE	65%	67%	70%	75%	Mensual
RS	72%	72%	73%	75%	Mensual
RC	60%	62%	65%	70%	Mensual
MTTD	2h30m	2h15m	2h00m	<2h	Real-time
FPR	28%	25%	20%	<15%	Semanal
VA Scor	72%	74%	78%	85%	Mensual
SATS	75%	78%	80%	85%	Mensual
Presup	—	€80K Q1	€150K Q2	€100K Q4	Trimestral
Inversión	—	€530K TOTAL			Anual
ROI Esp	—	125% Q1	20% Q2	Strategic	Trimestral

SLA Cumplimiento: Alertar si métrica desviación >10% vs. target.

Revisión: Mensual (SOC) | Trimestral (CISO) | Anual (Junta)

DIAPOSITIVA 18: CIERRE + PREGUNTAS

Portada Final:

EVALUACIÓN ACET GQM+PRAGMATIC ENERO 2026 IGM: 71% INTERMEDIATE PRAGMATIC Avg: 90% ✓ EXCELENTE Roadmap: €530K ROI 55% 8 meses "Conectando Estrategia a Métrica" Próximas Pasos: 1. Aprobación Presupuesto Junta 2. Designación Propietarios 3. Revisión GQM Mensual 4. Reporte Q1 (Abril 2026) Contactos: CISO: [Nombre] [Email] IT Manager: [Nombre] [Email] SOC Lead: [Nombre] [Email] Próxima Reunión: [Fecha Q1]
--

Espacio para Q&A: 15 minutos

Plantilla PowerPoint lista para personalización.